



INTERN REPORT

API - Vulnerability Assessment Findings Report

Business Confidential

Date: June 1th, 2026
Project: 897-19
Version 1.0

Table of Contents

Table of Contents	2
Confidentiality Statement.....	3
Disclaimer.....	3
Contact Information.....	3
Assessment Overview	4
Finding Severity Ratings	5
API Overview	6
Scope.....	7
Scope Exclusions	7
Client Allowances.....	7
Executive Summary	8
Security Strengths	9
Introduction	9
Vulnerabilities by Impact	10
External Penetration Test Findings.....	11
Unauthenticated Access to API Endpoint	11
Excessive Data Exposure.....	14
Lack of Rate Limiting.....	16

Confidentiality Statement

This document is the exclusive property of Demo API (DA) and Future Interns (FI). This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both DA and FI.

FIs may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

Disclaimer

This assessment was performed on the Demo API (DA). The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.

Time-limited engagements do not allow for a full evaluation of all security controls. FIs prioritized the assessment to identify the weakest security controls an attacker would exploit. FIs recommends conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

Contact Information

Name	Title	Contact Information
Demo API		
John Smith	VP, Information Security (CISO)	Office: +91xxxxxxxxx Email: john.smith@demo.com
Jim Smith	IT Manager	Office: +91xxxxxxxxx Email: jim.smith@demo.com
Joe Smith	Network Engineer	Office: +91xxxxxxxxx Email: joe.smith@demo.com
Future Interns		
Sujan Kumar C	Co-Founder & Proprietor	Office: +91xxxxxxxxx Email: sujan@futureinterns.com
Prajwal Singh	Co-Founder	Office: +91xxxxxxxxx Email: prajwal@futureinterns.com
Anwar Khan	Penetration Tester	Office: +91xxxxxxxxx Email: anwar@futureinterns.com

Assessment Overview

From May 22th, 2019 to June 1th, 2019, DS engaged FI to evaluate an assessment focused on passive and read-only testing techniques using API request tools to observe request-response behavior, returned data structures, and access control mechanisms. Particular attention was given to identifying common API security risks such as lack of authentication, unrestricted access to resources, excessive data exposure, and informative error responses.

The assessment was performed using a combination of manual testing techniques and industry-standard security tools. Identified findings were analyzed, assigned risk ratings based on their potential impact, and accompanied by remediation recommendations to improve the overall security posture of the application.

Finding Severity Ratings

The following table defines levels of severity and corresponding CVSS score range that are used throughout the document to assess vulnerability and risk impact.

Severity	CVSS V3 Score Range	Definition
Critical	9.0-10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
High	7.0-8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Moderate	4.0-6.9	Vulnerabilities exist but are not exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	0.1-3.9	Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
Informational	N/A	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.

API OVERVIEW

The API selected for this security risk analysis is **JSONPlaceholder**, a publicly available demo API commonly used for testing and learning purposes.

API Name: **JSONPlaceholder**

Base URL: <https://jsonplaceholder.typicode.com>

JSONPlaceholder provides fake online REST API endpoints that return sample data such as posts, comments, users, and todos. The API is designed for development and testing and does not require authentication for accessing most endpoints.

For this assessment, the following endpoint was tested:

- **GET /users** - Returns a list of user-related information

The purpose of analyzing this API was to understand how publicly accessible endpoints expose data and to identify potential security risks related to unrestricted access and data exposure using read-only techniques.

Scope

Assessment	Details
External Vulnerability Assessment	https://jsonplaceholder.typicode.com/

Scope Exclusions

Inscope

- ☐ Testing **public or demo APIs**
- ☐ Read-only requests (GET, safe POST where allowed)
- ☐ Documentation-based analysis
- ☐ Header, token, and response inspection

Out of scope

- ☐ Exploitation or bypass attempts
- ☐ Flooding / DoS testing
- ☐ Attacking private or production APIs

Client Allowances

DC did not provide any allowances to assist the testing.

Executive Summary

This report presents the findings of a passive vulnerability assessment conducted on the publicly accessible API <http://testphp.vulnweb.com>.

The API security risk analysis was conducted using a structured and non-intrusive approach. The publicly available API endpoints were tested using Postman to send standard HTTP requests and observe server responses.

Initially, the API endpoints were identified and accessed without authentication to determine whether access controls were enforced. The responses were reviewed to understand the type and sensitivity of data returned by the API. Request headers, response bodies, HTTP status codes, and error messages were analyzed to identify potential security risks such as unrestricted data access and excessive information exposure.

All testing was performed in a read-only manner without attempting to manipulate, exploit, or alter any data. The findings were documented clearly, and identified risks were classified based on their potential impact. Practical and business-friendly recommendations were provided to address the observed issues.

FINDINGS SUMMARY

The following table describes how FI performed:

Step	Action	Recommendation
1	The API endpoint allows access to user data without requiring authentication or authorization checks.	Implement authentication and authorization mechanisms for API access.
2	The API returns excessive user information, exposing more data than necessary for the requested operation.	Limit API responses to only required fields and apply data minimization principles.
3	The API does not enforce request rate limits, which may allow automated abuse, enumeration, or excessive requests.	Implement rate limiting and request throttling controls on API endpoints.

Security Strengths

INTRODUCTION

Application Programming Interfaces (APIs) are a core part of modern applications and are widely used to enable communication between systems, mobile apps, and web services. While APIs make data exchange efficient, insecure API implementations can expose sensitive information and create serious security risks for organizations.

This report focuses on analyzing the security posture of a publicly available API to identify common security risks such as missing authentication, excessive data exposure, and improper access controls. The assessment is conducted using read-only techniques to ensure that no harm is caused to the target API.

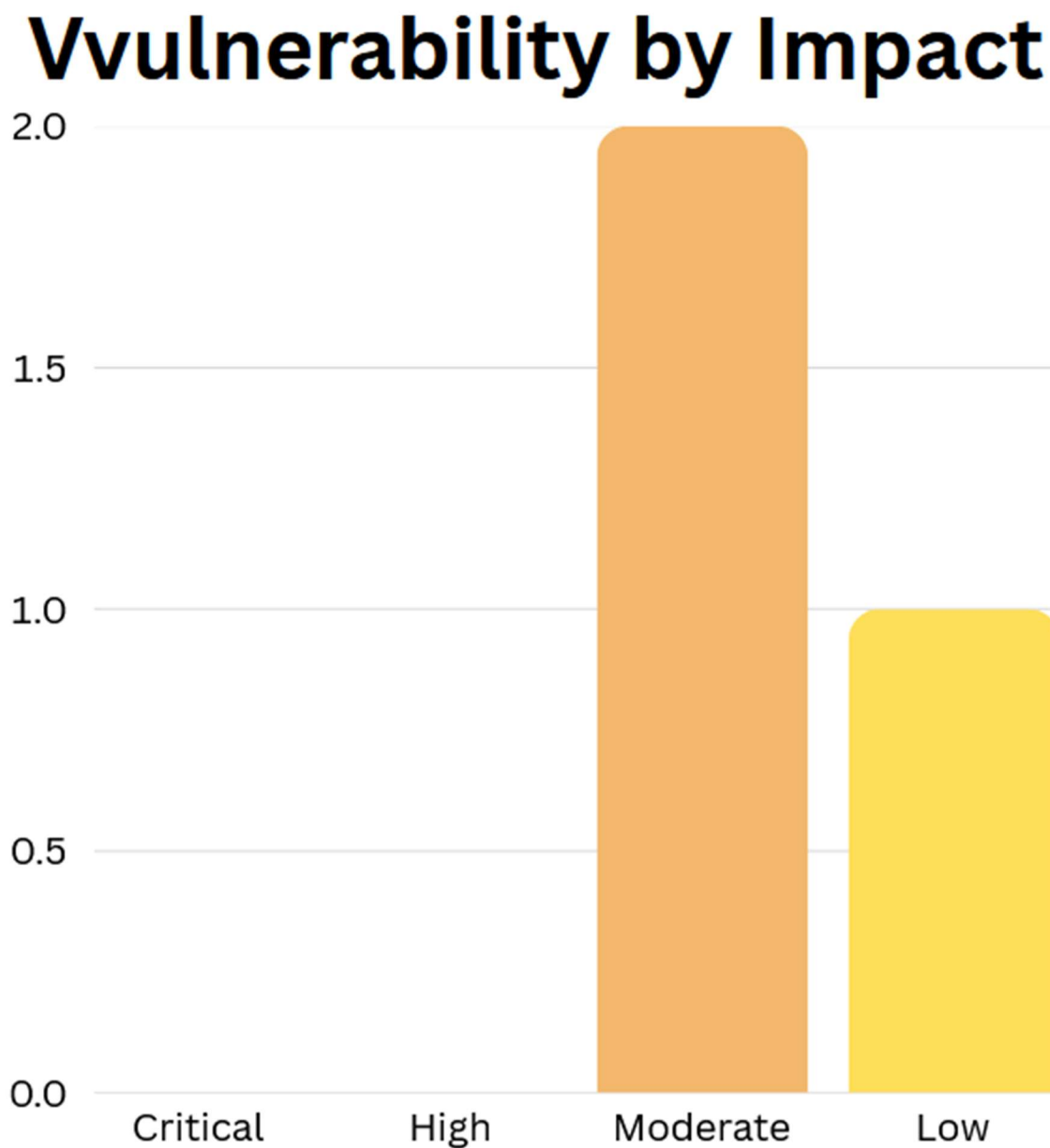
The objective of this analysis is to explain API security risks in a simple and business-friendly manner and to provide practical recommendations that can help improve API security. This assessment is intended strictly for educational purposes and does not involve any exploitation or unauthorized access.

Strengths

- ☐ The application successfully supported HTTPS communication.
- ☐ No critical-risk vulnerabilities were identified during the assessment.
- ☐ The application remained stable and accessible throughout testing.
- ☐ Security issues identified were primarily related to configuration weaknesses rather than direct system compromise.

Vulnerabilities by Impact

The following chart illustrates the vulnerabilities found by impact:



External Test Findings

Unauthenticated Access to API Endpoint

Description:	The API endpoint can be accessed without any authentication or authorization checks. Unauthenticated access allows anyone to retrieve data, increasing the risk of unauthorized data exposure and misuse.
Impact:	Medium
System/endpoint	https://jsonplaceholder.typicode.com/
References:	OWASP API Security Top 10 – API2:2023 Broken Authentication NIST SP 800-53 Rev. 5 – AC-3: Access Enforcement

Proof of Concept

Observed via GET requests sent through Postman without providing any authentication tokens.

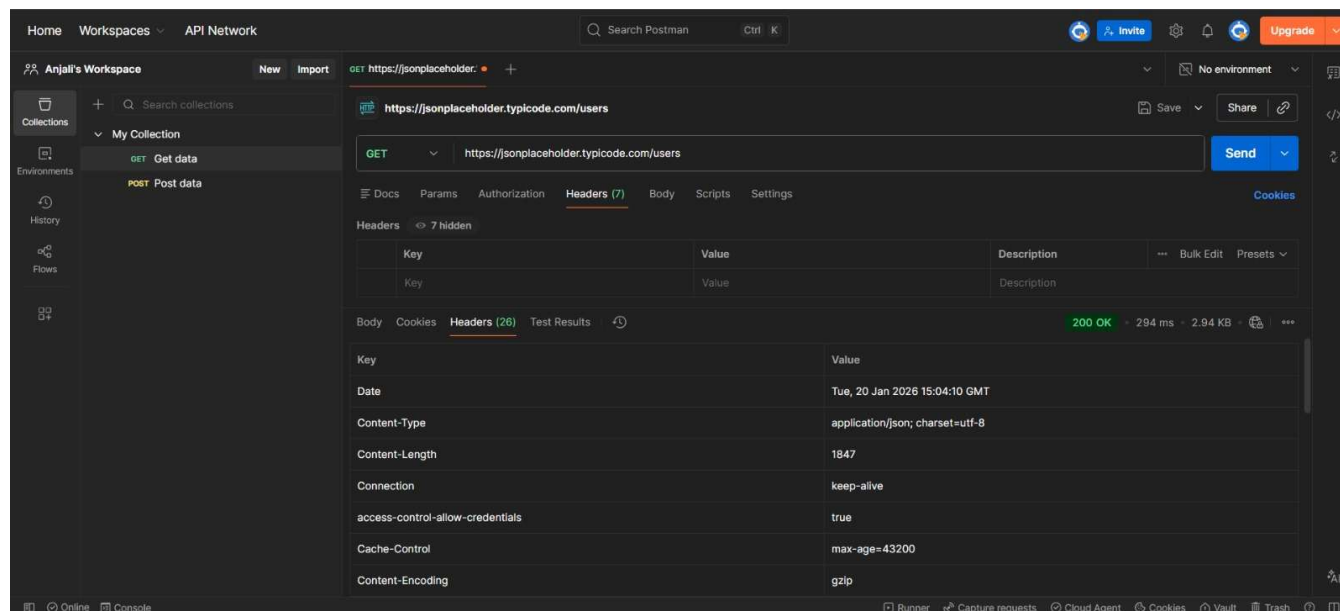


Figure 1: API Endpoint Accessible Without Authentication

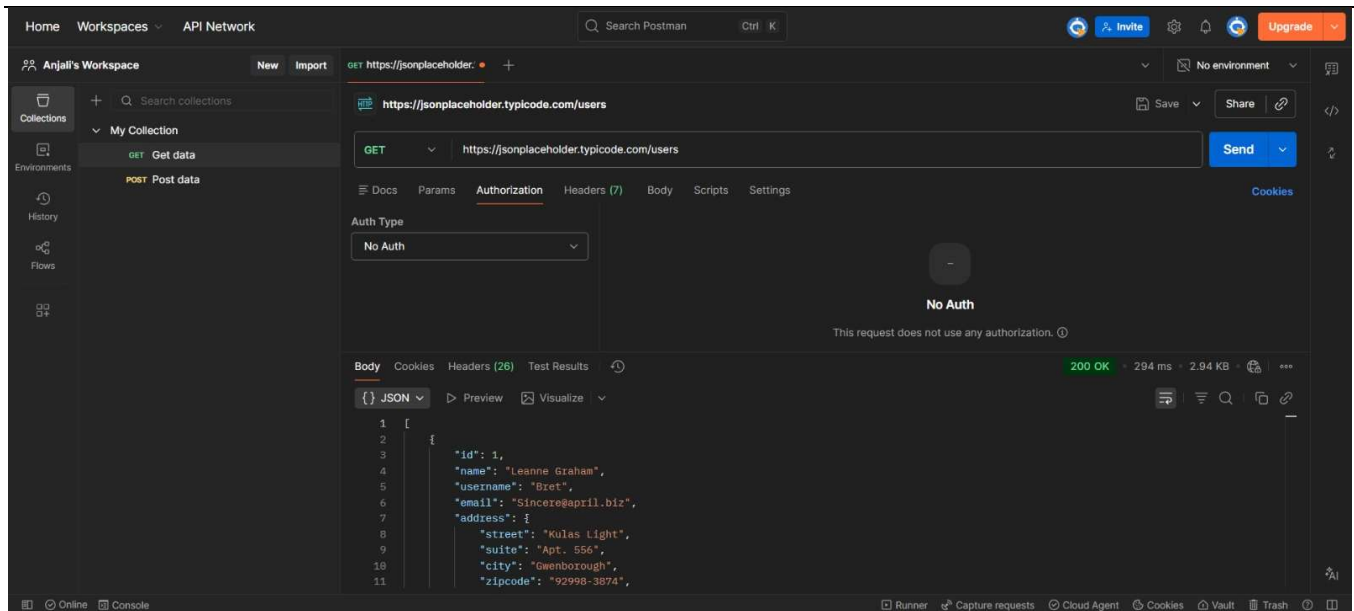


Figure 2: API Response Retrieved Without Authentication

Remediation

Who:	IT Team
Vector:	Remote
Action:	Item 1: implement strong authentication and authorization controls for all sensitive API endpoints. Additionally, FI recommends that DC: ▪ Enforce token-based authentication mechanisms such as JWT or OAuth 2.0. ▪ Validate user identity before processing API requests. ▪ Implement role-based access control (RBAC) to restrict access to authorized users only. ▪ Deny requests that do not contain valid authentication credentials. ▪ Regularly review and test API access controls to prevent unauthorized access.

Excessive Data Exposure

Description:	The API returns complete user records, including fields that may not be necessary for basic functionality. Exposing more data than required increases privacy risks and provides attackers with additional information that could be misused.
Impact:	Medium
System/endpoint	http://testphp.vulnweb.com/
References:	OWASP API Security Top 10 – API3:2019 Excessive Data Exposure NIST SP 800-53 Rev. 5 – AC-6: Least Privilege

Proof of Concept

API responses showed full user objects when accessing the `/users` endpoint.

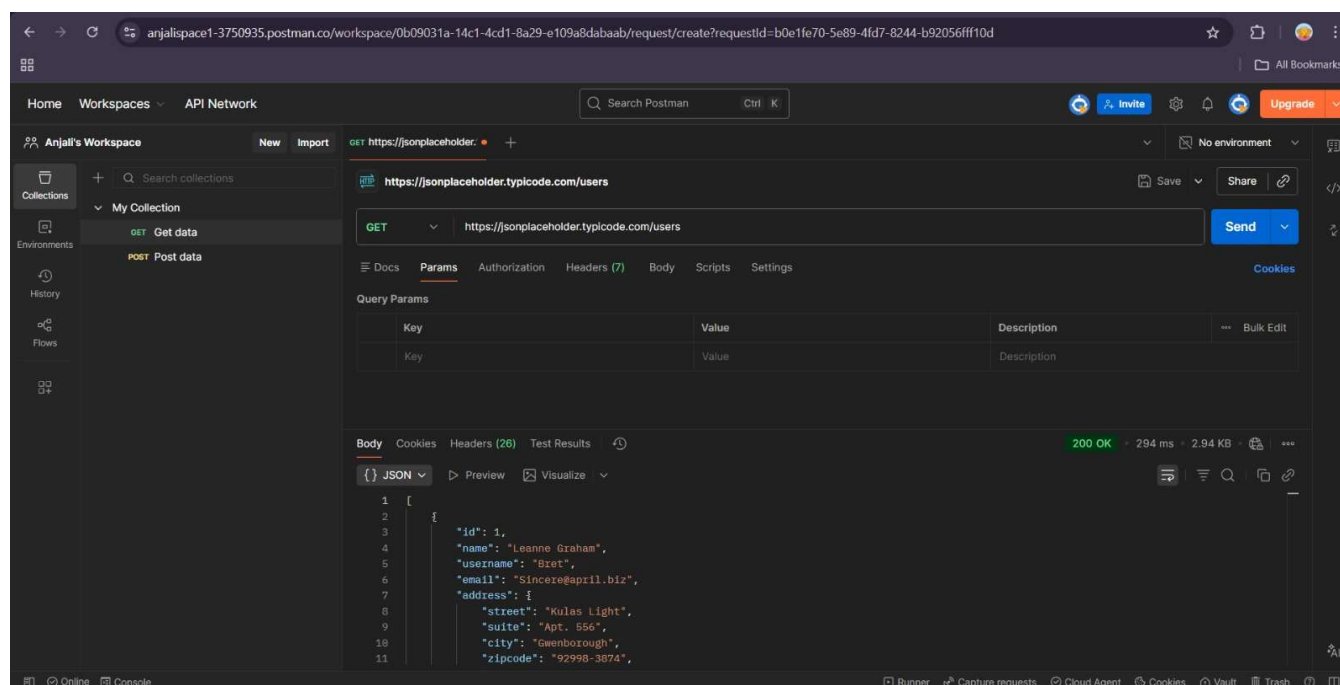


Figure 2: Excessive Data Exposure in API Response

Remediation

Who:	IT Team
Vector:	Remote
Action:	Item 1 limit API responses to only the data fields required by the requesting client. Additionally, FI recommends that DC: ▪ Implement data minimization principles across all API responses. ▪ Exclude sensitive or unnecessary fields from returned objects. ▪ Use response filtering and serialization controls to restrict exposed data. ▪ Review API schemas and response structures regularly. ▪ Apply the principle of least privilege when exposing user information through APIs.

Lack of Rate Limiting

Description:	The API does not appear to restrict the number of requests that can be made within a specific time frame. Without rate limiting, APIs can be abused through automated requests, leading to service abuse or performance issues.
Impact:	Low
System/endpoint	http://testphp.vulnweb.com/
References:	OWASP API Security Top 10 – API4:2019 Lack of Resources & Rate Limiting NIST SP 800-53 Rev. 5 – SC-5: Denial of Service Protection

Proof of Concept

Multiple consecutive requests returned successful responses without any rate-limit warnings or errors.

Remediation

Who:	IT Team
Vector:	Remote
Action:	Item 1: implement rate-limiting mechanisms on all publicly accessible API endpoints to control excessive or automated requests. Additionally, FI recommends that DC: ▪ Configure request throttling based on IP address, user account, or API key. ▪ Implement temporary blocking or rate-limit responses (HTTP 429) when thresholds are exceeded. ▪ Monitor and log excessive API usage for security analysis. ▪ Establish alerting mechanisms for unusual request patterns. ▪ Regularly review rate-limiting policies to ensure they align with business and security requirements.

